

Manual 31 — Implementación controlada de NYDFS 23 NYCRR Part 500

****Idioma:**** Español de América Latina (es-419)

****Línea base regulatoria:**** 23 NYCRR Part 500, modificado por la Segunda Enmienda efectiva el 1 de noviembre de 2023 y reverificado para publicación el 31 de agosto de 2026.

****Límite controlado:**** Esta edición es una traducción no oficial y una guía de implementación. No brinda asesoría jurídica, no determina condición de Covered Entity o Class A Company, no establece exenciones, no presenta archivos regulatorios y no certifica cumplimiento. Se mantienen separadas la regulación vinculante, los materiales explicativos de DFS, la práctica de la organización y la evidencia.

Chapter 01 — Propósito, alcance y jerarquía controlada de fuentes

Use Part 500 y los materiales finales de adopción de DFS como capa vinculante. Trate FAQs, capacitación, listas de verificación, cronogramas, explicaciones del Resource Center e industry letters como material explicativo o consultivo fechado; los procedimientos internos nunca deben presentarse como texto regulatorio.

Chapter 02 — Aplicabilidad y análisis de Covered Entity

Mantenga una evaluación documentada de aplicabilidad que identifique la autorización de DFS relevante y las actividades reguladas. Escale dudas sobre entidades, afiliadas, sucursales o perímetro regulatorio a análisis jurídico/regulatorio calificado en lugar de inferir estatus por descripciones genéricas.

Chapter 03 — Definiciones y gobierno terminológico

Mantenga un glosario controlado para conceptos como Covered Entity, Cybersecurity Event, Information System, Nonpublic Information, Senior Governing Body, CISO, Class A Company y Third Party Service Provider. Preserve el significado regulatorio cuando la terminología interna sea diferente.

Chapter 04 — Exenciones y controles de exención limitada

Documento base regulatoria, hechos, aprobación, estado de presentación, vigencia, obligaciones que continúan y disparadores de cambio para cada exención. Revalide cuando cambien tamaño, ingresos, operaciones, afiliación u otros hechos relevantes.

Chapter 05 — Determinación de Class A Company y obligaciones

Mantenga una determinación fechada de Class A Company basada en la definición regulatoria vigente y los hechos aplicables. Cuando corresponda, identifique requisitos reforzados sin extenderlos a entidades para las cuales Part 500 no los exige.

Chapter 06 — Gobierno de ciberseguridad y responsabilidad superior

Defina responsabilidades del Senior Governing Body, informes de gestión, escalamiento, decisiones de recursos y aceptación de riesgo. La evidencia debe demostrar supervisión informada y no solo que ciberseguridad apareció en una agenda.

Chapter 07 — Rol, autoridad, informes y evidencia del CISO

Documente autoridad, independencia o línea de reporte, responsabilidades, recursos y reportes requeridos del CISO. Conserve informes, hallazgos, asuntos materiales, decisiones de remediación y constancias de revisión.

Chapter 08 — Diseño y mantenimiento del programa de ciberseguridad

Opere un programa basado en riesgo para proteger Information Systems y Nonpublic Information y apoyar detección, respuesta, recuperación y deberes regulatorios. Mapee componentes a propietarios, políticas, procedimientos, tecnología, evidencia y pruebas.

Chapter 09 — Marco de políticas de ciberseguridad

Mantenga políticas escritas aprobadas que cubran los temas de Part 500 aplicables. Cada política debe indicar propietario, alcance, autoridad de aprobación, revisión, procedimientos, evidencia, excepciones y disparadores de cambio.

Chapter 10 — Metodología de evaluación de riesgo

Realice y mantenga la risk assessment exigida por Part 500 con criterios definidos, amenazas, vulnerabilidades, operaciones, sistemas, Nonpublic Information, controles y cambios materiales. Conserve metodología, entradas, supuestos, aprobaciones, riesgos y decisiones de tratamiento.

Chapter 11 — Inventario de activos y ciclo de vida tecnológico

Mantenga el inventario de Information Systems requerido por la regulación modificada con atributos, propiedad, actualización y retención adecuados. Concilie cobertura de nube, endpoints, servidores, aplicaciones, redes, datos, IA y otras tecnologías relevantes.

Chapter 12 — Privilegios de acceso y mínimo privilegio

Limite acceso según responsabilidades y necesidad legítima. Defina alta, aprobación, revisión periódica, traslado, baja, acceso de emergencia, excepciones y evidencia que demuestre que el acceso sigue siendo apropiado.

Chapter 13 — Gestión de acceso privilegiado

Aplice gobierno reforzado a cuentas privilegiadas, cuentas de servicio y herramientas administrativas. Registre propietario, necesidad, autenticación, monitoreo, revisión, salvaguardas, uso de emergencia y retiro oportuno.

Chapter 14 — Requisitos de MFA y excepciones

Implemente MFA conforme a Part 500 modificado y a los hechos aplicables. Toda alternativa o excepción permitida debe documentar base regulatoria, aprobación del CISO cuando proceda, riesgo, controles compensatorios, alcance, vigencia y revalidación.

Chapter 15 — Gestión de vulnerabilidades y penetration testing

Opere escaneo/evaluación de vulnerabilidades, remediación, penetration testing y seguimiento basado en riesgo con frecuencia y alcance aplicables. Conserve metodología, hallazgos, severidad, remediación, retest y excepciones.

Chapter 16 — Desarrollo seguro y seguridad de aplicaciones

Mantenga procedimientos escritos de desarrollo seguro y application security para aplicaciones internas y externas cuando aplique. Incluya diseño, revisión de código/cambios, dependencias, pruebas, remediación y aprobación de release.

Chapter 17 — Cifrado y decisiones sobre controles compensatorios

Proteja Nonpublic Information en tránsito y en reposo mediante cifrado acorde con Part 500. Cuando una alternativa permitida sea necesaria, documente decisión, aprobación, controles compensatorios, riesgo, duración, monitoreo y reconsideración periódica.

Chapter 18 — Monitoreo, logging y detección

Implemente monitoreo basado en riesgo de actividad de usuarios autorizados y controles diseñados para detectar acceso, uso o manipulación no autorizados. Mantenga logging, alertas, revisión, retención, tuning, escalamiento e investigación.

Chapter 19 — Salvaguardas de endpoint, red e infraestructura

Aplique controles basados en riesgo contra código malicioso y actividad no autorizada en endpoints, redes, correo, web, acceso remoto, infraestructura y canales administrativos. Mantenga separados los requisitos específicos de Class A de las obligaciones base.

Chapter 20 — Riesgo de ciberseguridad de Third Party Service Providers

Mantenga un programa/política para Third Party Service Providers que cubra evaluación, due diligence, prácticas mínimas, contratos, acceso, notificación de incidentes, monitoreo y terminación. La tercerización no elimina las responsabilidades de Part 500 de la Covered Entity.

Chapter 21 — Concientización y capacitación

Proporcione capacitación periódica, como mínimo anual, y actualícela según riesgos identificados. Incluya contenido de ingeniería social y conserve población, finalización, excepciones, versión del contenido, fecha y seguimiento.

Chapter 22 — Planificación y ejecución de incident response

Mantenga un plan que cubra preparación, roles, escalamiento, investigación, contención, erradicación, recuperación, comunicaciones, evidencia, análisis regulatorio, lecciones aprendidas y actualización. Ejercicios y eventos reales deben generar remediación trazable.

Chapter 23 — Business continuity y disaster recovery

Mantenga planes BCDR alineados con Part 500 modificado y escenarios cibernéticos. Defina operaciones críticas, objetivos de recuperación, backups, pruebas de restauración, dependencias, comunicaciones, pruebas y mejoras.

Chapter 24 — Determinación y escalamiento de Cybersecurity Event

Use un proceso documentado para decidir si un hecho cumple la definición regulatoria de Cybersecurity Event y si activa umbrales adicionales. Conserve hechos, momento de conocimiento, análisis, propietario de decisión y escalamiento.

Chapter 25 — Aviso al Superintendent y registros de decisión

Mantenga un proceso sensible al tiempo para eventos reportables a DFS. Registre criterios, timestamps, autoridad, información presentada, comunicaciones suplementarias, confirmación del portal y evidencia; no sustituya el criterio regulatorio por severidad interna.

Chapter 26 — Notificación de extortion payment y límites de evidencia

Mantenga un proceso controlado para pagos de extorsión que puedan activar notificación o información de seguimiento. Conserve autorización, tiempos, hechos del pago, revisiones legales/sanciones cuando apliquen, análisis y evidencia de notificación.

Chapter 27 — Gobierno de certificación / acknowledgment anual

Opere un proceso anual que distinga certificación de material compliance de acknowledgment of noncompliance cuando corresponda. Mantenga firmantes responsables, evidencia, brechas conocidas, remediación, fundamento de decisión y confirmación de presentación.

Chapter 28 — Supervisión del Senior Governing Body y retención

Entregue información suficiente sobre riesgos materiales, incidentes, brechas, informes del CISO, remediación, excepciones, recursos y cambios significativos. Conserve minutas, materiales, aprobaciones y seguimiento sin presentarlos como aseguramiento independiente.

Chapter 29 — Gobierno de remediación, excepciones y aceptación de riesgo

Gestione deficiencias con propietario, severidad, causa raíz, acciones, fecha objetivo, salvaguardas interinas, validación y cierre. La aceptación de riesgo no puede eliminar silenciosamente una obligación de Part 500.

Chapter 30 — Pruebas, métricas, aseguramiento y mejora continua

Defina pruebas y métricas que demuestren operación y deterioro del programa. Conserve alcance, población, método, resultados, limitaciones, tendencias, seguimiento e independencia cuando sea requerida; porcentajes de dashboard no prueban cumplimiento.

Chapter 31 — Arquitectura de evidencia, auditabilidad y retención

Mantenga evidencia trazable entre tema regulatorio, política, procedimiento, propietario, sistema, periodo, prueba, excepción, hallazgo, remediación, aprobación y versión de fuente. Proteja información sensible y aplique retención conforme a obligaciones aplicables.

Chapter 32 — Control de cambio regulatorio y roadmap de implementación

Revalide Part 500 y el DFS Cybersecurity Resource Center antes de cada release. Evalúe enmiendas, FAQs, guidance, enforcement, advisories, cambios de filing y deadlines, y actualice mapeos, procedimientos, evidencia, capacitación y planes mediante cambio controlado.

Conjunto mínimo de evidencia

Mantenga, según aplique: registro de fuente/versión; análisis de aplicabilidad; determinaciones de exención y Class A; mandato e informe del CISO; programa; políticas; risk assessment; inventario; revisiones de acceso; decisiones MFA; evidencia de vulnerabilidades/penetration testing; application security; cifrado; monitoreo; terceros; capacitación; incidentes/BCDR; análisis y confirmaciones de reporting DFS; certificación/acknowledgment anual; supervisión del Senior Governing Body; remediación/excepciones; métricas/pruebas; y verificación de fuentes de release.